RaceDay API Endpoint Plan

Module: Programming 2B (PROG6212) | Student: ST10458180 | Part 1 – System Planning, Section B

Authentication

HTTP Method	Route	Description	Role Required	Request Body	Expected Response
POST	/api/auth/register	Creates a new user account as either an Organiser or a Participant. The password is hashed before it is saved.	None (public)	{ fullName, email, password, role }	201 Created – new user id and role. 400 Bad Request – missing/invalid fields, unknown role or email already in use.
POST	/api/auth/login	Validates a user's email and password and starts a session (session cookie) that stores the user id and role for later requests.	None (public)	{ email, password }	200 OK – user details and role, session started. 401 Unauthorized – invalid credentials.
POST	/api/auth/logout	Ends the current session by clearing it.	None (public)	None	200 OK – logged out.

User Profile

HTTP Method	Route	Description	Role Required	Request Body	Expected Response
GET	/api/users/me	Returns the profile of the currently logged in user (Organiser or Participant).	Any (logged in)	None	200 OK – user profile fields. 401 Unauthorized – not logged in.
PUT	/api/users/me	Lets the logged in user update their own profile information.	Any (logged in)	{ fullName, email }	200 OK – updated profile. 400 Bad Request – invalid data or email used by another account. 401 Unauthorized.

Events

HTTP Method	Route	Description	Role Required	Request Body	Expected Response
GET	/api/events	Returns a list of events so users can browse them. Optional query upcomingOnly=true returns only events that have not happened yet.	Any (logged in)	None	200 OK – array of events. 401 Unauthorized.
GET	/api/events/{id}	Returns the full detail of a single event.	Any (logged in)	None	200 OK – event detail. 401 Unauthorized. 404 Not Found – event does not exist.
POST	/api/events	Allows an Organiser to create a new event.	Organiser	{ eventName, description, eventDate, location, distanceKm, eventType }	201 Created – the new event. 400 Bad Request – missing/invalid fields. 401 Unauthorized. 403 Forbidden – not an Organiser.
PUT	/api/events/{id}	Allows an Organiser to update an event they created.	Organiser	{ eventName, description, eventDate, location, distanceKm, eventType }	200 OK – updated event. 400 Bad Request. 401 Unauthorized. 403 Forbidden – not an Organiser or not the owner. 404 Not Found.
DELETE	/api/events/{id}	Allows an Organiser to delete an event they created (also removes its categories, enrolments and results).	Organiser	None	204 No Content – deleted. 401 Unauthorized. 403 Forbidden – not an Organiser or not the owner. 404 Not Found.

Categories

HTTP Method	Route	Description	Role Required	Request Body	Expected Response
GET	/api/events/{eventId}/categories	Returns all categories available for a specific event (e.g. Under 20, Senior, 10km).	Any (logged in)	None	200 OK – array of categories. 401 Unauthorized. 404 Not Found – event does not exist.

HTTP Method	Route	Description	Role Required	Request Body	Expected Response
POST	/api/events/{eventId}/categories	Allows an Organiser to add a new age/distance category to their event.	Organiser	{ categoryName, minAge, maxAge }	201 Created – the new category. 400 Bad Request – invalid data. 401 Unauthorized. 403 Forbidden – not an Organiser or not the owner. 404 Not Found – event does not exist.
PUT	/api/categories/{id}	Allows an Organiser to update a category on their own event.	Organiser	{ categoryName, minAge, maxAge }	200 OK – updated category. 400 Bad Request. 401 Unauthorized. 403 Forbidden. 404 Not Found.
DELETE	/api/categories/{id}	Allows an Organiser to remove a category from their own event.	Organiser	None	204 No Content. 401 Unauthorized. 403 Forbidden. 404 Not Found. 409 Conflict – participants are already enrolled in the category.

Event Enrolments

HTTP Method	Route	Description	Role Required	Request Body	Expected Response
POST	/api/events/{eventId}/enrolments	Lets a Participant enter an event under a chosen category. Links the participant, the event and the category.	Participant	{ categoryId }	201 Created – enrolment record. 400 Bad Request – category belongs to a different event. 401 Unauthorized. 403 Forbidden – not a Participant. 404 Not Found – event or category missing. 409 Conflict – already enrolled in this event.
GET	/api/events/{eventId}/enrolments	Lets an Organiser view everyone who has enrolled in their event.	Organiser	None	200 OK – array of enrolments. 401 Unauthorized. 403 Forbidden – not an Organiser or not the owner. 404 Not Found – event does not exist.
GET	/api/users/me/enrolments	Lets a Participant view their own enrolment/participation history.	Participant	None	200 OK – array of the participant's enrolments. 401 Unauthorized. 403 Forbidden – not a Participant.

Results

HTTP Method	Route	Description	Role Required	Request Body	Expected Response
POST	/api/enrolments/{enrolmentId}/results	Lets an Organiser capture a finish time and finishing position for a participant after the event.	Organiser	{ finishTime, finishPosition }	201 Created – result record. 400 Bad Request – invalid data. 401 Unauthorized. 403 Forbidden – not an Organiser or not the owner. 404 Not Found – enrolment does not exist. 409 Conflict – result already captured.
GET	/api/events/{eventId}/results	Returns the full result list for an event (e.g. a results board), ordered by finishing position.	Any (logged in)	None	200 OK – array of results. 401 Unauthorized. 404 Not Found – event does not exist.
GET	/api/users/me/results	Lets a Participant view only their own results across all events.	Participant	None	200 OK – array of the participant's results. 401 Unauthorized. 403 Forbidden – not a Participant.

Notes

- Authentication uses server side sessions. Login stores the user id and role in the session and the browser keeps a session cookie, so no token is sent manually.
- Every endpoint except register, login and logout needs a logged in user. A request without a session gets 401 Unauthorized, and a logged in user with the wrong role gets 403 Forbidden.
- Organiser endpoints also check that the logged in Organiser owns the event (via OrganiserID) before allowing the action.
- This plan matches the ERD in /docs/ERD_RaceDay.png and the implemented API in /Part2-API.